

# Azure Compliance Implementation Checklist

|              |                                      |
|--------------|--------------------------------------|
| Document:    | sample_azure_compliance_document.txt |
| Frameworks:  | AZURE, GDPR, ISO27001, ISO27018      |
| Total Items: | 19                                   |
| Generated:   | 2025-11-24 20:32:41 UTC              |

## Item #1: Implement Standardized Hardened Workstation Configurations for Administrators

Priority: CRITICAL

Effort: Complex

**Description:**

Enhance security by implementing standardized hardened workstation configurations for administrators accessing Azure resources. This reduces the attack surface and prevents credential theft.

**Gap Addressed:** Lack of specific details on standardized hardened workstation configurations for administrators accessing Azure resources.

**Azure Portal Navigation:** Azure Portal > Intune > Devices > Configuration profiles

**Settings to Configure:**

|                 |                                                                                                      |
|-----------------|------------------------------------------------------------------------------------------------------|
| Setting Name:   | BitLocker Drive Encryption                                                                           |
| Current Value:  | Not configured                                                                                       |
| Required Value: | Enabled and Enforced                                                                                 |
| Location:       | Intune > Devices > Configuration profiles > Create profile > Windows 10 and later > Settings catalog |

**Step-by-Step Implementation Guide:**

**Step 1: Navigate to Azure Portal > Intune**

Click on 'Intune' in the left navigation menu or search for it.  
*What to look for: You should see the Microsoft Intune overview page.*

**Step 2: Go to Devices > Configuration profiles**

In the left menu, expand 'Devices' and click 'Configuration profiles'.  
*What to look for: You should see the list of configuration profiles.*

**Step 3: Create a new profile for Windows 10 and later using Settings catalog**

Click '+ Create profile', select 'Windows 10 and later' for Platform, and 'Settings catalog' for profile type. Name the profile 'Hardened Admin Workstation Configuration'.  
*What to look for: You should see the profile creation wizard.*

**Step 4: Configure BitLocker Drive Encryption**

In the Settings catalog, search for 'BitLocker'. Configure the following settings: 'Configure drive encryption method for operating system drives' to 'AES-XTS 128-bit', 'Configure user storage of BitLocker recovery information' to 'Allow user to create recovery password and key', 'Require device encryption' to 'Yes'.

*What to look for: The BitLocker settings should be configured as specified.*

**Step 5: Configure Windows Defender Antivirus**

In the Settings catalog, search for 'Windows Defender Antivirus'. Configure the following settings: 'Turn on real-time protection' to 'Enabled', 'Turn on cloud-delivered protection' to 'Enabled', 'Configure cloud block level' to 'High blocking level'.

*What to look for: The Windows Defender Antivirus settings should be configured as specified.*

**Step 6: Configure Account Policies**

In the Settings catalog, search for 'Account Policies'. Configure the following settings: 'Password complexity' to 'Required', 'Minimum password length' to '14', 'Maximum password age (days)' to '90'.

*What to look for: The Account Policies settings should be configured as specified.*

**Step 7: Assign the profile to a security group containing administrator accounts**

Go to 'Assignments' tab and add a security group containing the administrator accounts.

*What to look for: The profile should be assigned to the correct security group.*

**Verification Steps:**

- Step 1: On a workstation assigned to the profile, verify that BitLocker is enabled and the drive is encrypted.
- Step 2: Verify that Windows Defender Antivirus is running and up-to-date.
- Step 3: Verify that the password policy is enforced and meets the configured requirements.

**Azure Services Required:** Azure Active Directory, Intune, Azure Security Center

**Expected Outcome:** Administrators are using hardened workstations, reducing the risk of compromise.

**Framework Reference:** Azure Security Benchmark v3 - CM-7: Implement secure workstation configurations for administrators

**Additional Notes:** Consider using Microsoft Defender for Endpoint for enhanced threat detection and response on administrator workstations.

## Item #1: Implement Data Protection Impact Assessment (DPIA) Process

Priority:

CRITICAL

Effort:

Complex

### Description:

Establish a documented process for conducting DPIAs for all high-risk processing activities. This includes identifying processing activities, assessing risks, and implementing mitigation measures. This is a CRITICAL requirement under GDPR Article 35.

**Gap Addressed:** Lack of documented Data Protection Impact Assessments (DPIAs) as required by GDPR Article 35 for high-risk processing activities.

**Azure Portal Navigation:** Azure Portal > All services > Search for 'Privacy' or 'Purview'

### Settings to Configure:

|                 |                                                              |
|-----------------|--------------------------------------------------------------|
| Setting Name:   | DPIA Process Documentation                                   |
| Current Value:  | None                                                         |
| Required Value: | Documented DPIA process, including templates and procedures. |
| Location:       | Document repository (e.g., Azure DevOps, SharePoint)         |

### Step-by-Step Implementation Guide:

#### Step 1: Navigate to Azure Portal and search for 'Privacy' or 'Purview'

In the Azure Portal search bar, type 'Privacy' or 'Purview' and select the relevant service.

*What to look for:* You should see the Azure Privacy or Purview overview page.

#### Step 2: Create a DPIA Template

Develop a DPIA template that includes sections for describing the processing activity, identifying risks, assessing the severity and likelihood of risks, and documenting mitigation measures. Consider using the ICO's DPIA template as a starting point.

*What to look for:* A structured document template with sections for each DPIA requirement.

#### Step 3: Document DPIA Procedures

Create a documented procedure for conducting DPIAs, including roles and responsibilities, timelines, and approval processes. Store this documentation in a central, accessible location (e.g., Azure DevOps Wiki, SharePoint).

*What to look for:* A written procedure outlining the steps for conducting a DPIA.

#### Step 4: Identify High-Risk Processing Activities

Review all data processing activities within Azure and identify those that are likely to result in a high risk to the rights and freedoms of natural persons. Examples include processing special categories of data, systematic monitoring, and large-scale processing.

*What to look for:* A list of processing activities that require a DPIA.

#### Step 5: Conduct DPIAs for Identified Activities

For each high-risk processing activity, complete the DPIA template, assess risks, and document mitigation measures. Ensure that the DPIA is reviewed and approved by relevant stakeholders.

*What to look for:* Completed DPIA documents for each high-risk processing activity.

### Verification Steps:

- Step 1: Review the documented DPIA process to ensure it covers all required elements.
- Step 2: Verify that DPIAs have been conducted for all identified high-risk processing activities.
- Step 3: Confirm that DPIAs are regularly reviewed and updated.

**Azure Services Required:** Azure Privacy, Azure Purview

**Expected Outcome:** Compliance with GDPR Article 35, demonstrating a proactive approach to data protection.

**Framework Reference:** GDPR Article 35

**Additional Notes:** Consider using a DPIA tool to streamline the process. Ensure that DPIAs are conducted before implementing new processing activities.

## Item #2: Designate a Data Protection Officer (DPO) or Document Justification for Not Needing One

Priority:

CRITICAL

Effort:

Moderate

### Description:

Determine whether a DPO is required based on GDPR Articles 37-39. If required, designate a DPO and provide them with the necessary resources and authority. If not required, document the justification for not designating a DPO.

**Gap Addressed:** Absence of a designated Data Protection Officer (DPO) or justification for not needing one, as per GDPR Articles 37-39.

**Azure Portal Navigation:** N/A - Documentation and organizational structure

### Settings to Configure:

|                 |                                                                 |
|-----------------|-----------------------------------------------------------------|
| Setting Name:   | DPO Designation                                                 |
| Current Value:  | None                                                            |
| Required Value: | Designated DPO or documented justification for not needing one. |
| Location:       | Organizational chart and documentation repository               |

### Step-by-Step Implementation Guide:

#### Step 1: Assess the Need for a DPO

Evaluate whether the organization's core activities involve regular and systematic monitoring of data subjects on a large scale or processing of special categories of data. Refer to GDPR Articles 37-39 for specific criteria.

*What to look for: A clear determination of whether a DPO is required based on GDPR criteria.*

#### Step 2: Designate a DPO (If Required)

If a DPO is required, appoint a qualified individual with the necessary expertise and resources. Document the DPO's responsibilities, authority, and reporting structure.

*What to look for: A formal appointment letter or job description for the DPO.*

#### Step 3: Document Justification for Not Needing a DPO (If Not Required)

If a DPO is not required, document the reasons why, based on the GDPR criteria. This documentation should be reviewed and approved by senior management.

*What to look for: A written justification for not designating a DPO, signed by senior management.*

#### Step 4: Communicate DPO Information

If a DPO is appointed, communicate their contact information to data subjects and relevant authorities.

*What to look for: Published contact information for the DPO (e.g., on the organization's website).*

### Verification Steps:

- Step 1: Review the assessment of the need for a DPO to ensure it is accurate and complete.
- Step 2: Verify that a DPO has been designated (if required) and provided with the necessary resources.
- Step 3: Confirm that the justification for not needing a DPO (if applicable) is documented and approved.

**Azure Services Required:** None

**Expected Outcome:** Compliance with GDPR Articles 37-39, demonstrating a clear understanding of DPO requirements.

**Framework Reference:** GDPR Articles 37-39

**Additional Notes:** Even if a DPO is not legally required, consider appointing a privacy officer to oversee data protection activities.

## Item #3: Document Lawful Basis for Processing Personal Data

Priority:

CRITICAL

Effort:

Moderate

### Description:

For each specific processing activity, identify and document the lawful basis for processing personal data, as required by GDPR Article 6. This could be consent, contract, legal obligation, vital interests, public task, or legitimate interests.

**Gap Addressed:** Insufficient detail on the lawful basis for processing personal data for each specific processing activity, as required by GDPR Article 6. The document mentions GDPR compliance but doesn't specify the lawful basis used (e.g., consent, contract, legal obligation).

**Azure Portal Navigation:** N/A - Documentation and data flow diagrams

### Settings to Configure:

|                 |                                                        |
|-----------------|--------------------------------------------------------|
| Setting Name:   | Lawful Basis Documentation                             |
| Current Value:  | Not specified for each processing activity             |
| Required Value: | Documented lawful basis for each processing activity.  |
| Location:       | Data processing inventory and documentation repository |

### Step-by-Step Implementation Guide:

#### Step 1: Create a Data Processing Inventory

Develop a comprehensive inventory of all data processing activities within Azure, including the types of personal data processed, the purposes of processing, and the data subjects involved.

*What to look for: A detailed list of all data processing activities.*

#### Step 2: Identify Lawful Basis for Each Activity

For each processing activity, determine the appropriate lawful basis for processing personal data. Consider the specific circumstances of each activity and consult with legal counsel if necessary.

*What to look for: A documented lawful basis (e.g., consent, contract, legal obligation) for each processing activity.*

#### Step 3: Document Lawful Basis

Document the lawful basis for each processing activity in the data processing inventory. Include a clear explanation of why that lawful basis is appropriate.

*What to look for: A clear and concise explanation of the lawful basis for each processing activity in the data processing inventory.*

#### Step 4: Implement Consent Mechanisms (If Applicable)

If consent is used as the lawful basis, implement mechanisms for obtaining and managing consent, including providing clear and concise information to data subjects and allowing them to withdraw their consent easily.

*What to look for: Consent forms, consent management platforms, and procedures for withdrawing consent.*

### Verification Steps:

- Step 1: Review the data processing inventory to ensure it is complete and accurate.
- Step 2: Verify that a lawful basis has been identified and documented for each processing activity.
- Step 3: Confirm that consent mechanisms (if applicable) are implemented and functioning correctly.

**Azure Services Required:** Azure Active Directory, Azure Data Lake Storage, Azure SQL Database

**Expected Outcome:** Compliance with GDPR Article 6, demonstrating a legal basis for all data processing activities.

**Framework Reference:** GDPR Article 6

**Additional Notes:** Regularly review the lawful basis for processing to ensure it remains appropriate. Document any changes to the lawful basis.

# Item #1: Define and Document ISMS Scope

Priority:

CRITICAL

Effort:

Complex

## Description:

Establish and document the scope of the Information Security Management System (ISMS). This includes defining the boundaries, applicability, and organizational units covered by the ISMS. This is a fundamental requirement for ISO 27001 compliance.

**Gap Addressed:** Lack of documented ISMS scope definition as required by ISO 27001:2022

**Azure Portal Navigation:** N/A - Documentation and Policy Definition

## Settings to Configure:

|                 |                                                                                                   |
|-----------------|---------------------------------------------------------------------------------------------------|
| Setting Name:   | N/A                                                                                               |
| Current Value:  | Undefined                                                                                         |
| Required Value: | Documented scope including organizational units, physical locations, and Azure services in scope. |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint)                                         |

## Step-by-Step Implementation Guide:

### Step 1: Identify all organizational units, physical locations, and Azure services that fall within the scope of the ISMS.

Conduct a thorough review of the organization's structure, operations, and Azure environment. Consider legal, regulatory, and contractual requirements.

*What to look for:* A comprehensive list of all in-scope elements.

### Step 2: Document the ISMS scope in a formal document.

Create a document that clearly defines the boundaries of the ISMS. Include a description of the organizational units, physical locations, and Azure services covered. Specify any exclusions and the rationale for those exclusions.

*What to look for:* A well-structured document with clear and concise language.

### Step 3: Obtain approval for the ISMS scope from senior management.

Present the ISMS scope document to senior management for review and approval. Ensure that they understand the implications of the scope definition.

*What to look for:* Signed approval from senior management.

### Step 4: Publish the ISMS scope document to all relevant stakeholders.

Make the ISMS scope document readily available to all employees, contractors, and other relevant parties. Consider using a central document repository such as Azure DevOps Wiki or SharePoint.

*What to look for:* Evidence that the document has been distributed and is accessible.

## Verification Steps:

- Step 1: Review the ISMS scope document to ensure that it accurately reflects the organization's operations and Azure environment.
- Step 2: Verify that the ISMS scope document has been approved by senior management.
- Step 3: Confirm that the ISMS scope document is readily available to all relevant stakeholders.

**Azure Services Required:** Azure Purview, Azure DevOps (for documentation)

**Expected Outcome:** A clearly defined and documented ISMS scope that meets the requirements of ISO 27001:2022.

**Framework Reference:** ISO 27001:2022 Clause 4.3

**Additional Notes:** The ISMS scope should be reviewed and updated regularly to reflect changes in the organization's operations and Azure environment.

## Item #2: Implement and Document Confidentiality/Non-Disclosure Agreements

Priority:

CRITICAL

Effort:

Moderate

### Description:

Establish and document confidentiality or non-disclosure agreements (NDAs) with employees, contractors, and other third parties who have access to sensitive information. This is crucial for protecting confidential data and complying with ISO 27001:2022 requirement 6.6.

**Gap Addressed:** Absence of documented confidentiality or non-disclosure agreements (6.6)

**Azure Portal Navigation:** N/A - Policy and Document Management

### Settings to Configure:

|                 |                                                           |
|-----------------|-----------------------------------------------------------|
| Setting Name:   | N/A                                                       |
| Current Value:  | No standard NDA in place                                  |
| Required Value: | A documented and approved NDA template.                   |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint) |

### Step-by-Step Implementation Guide:

#### Step 1: Develop a standard confidentiality/non-disclosure agreement (NDA) template.

Consult with legal counsel to create an NDA template that is appropriate for the organization's needs. The NDA should cover the types of information that are considered confidential, the obligations of the parties, and the consequences of breach.

*What to look for: A legally sound NDA template that protects the organization's confidential information.*

#### Step 2: Ensure all employees, contractors, and other third parties sign the NDA.

Require all individuals who have access to sensitive information to sign the NDA before they are granted access. Maintain a record of all signed NDAs.

*What to look for: Signed NDAs for all relevant individuals.*

#### Step 3: Store signed NDAs securely.

Store signed NDAs in a secure location, such as a password-protected folder on a network drive or in a document management system. Implement access controls to restrict access to the NDAs to authorized personnel.

*What to look for: Secure storage of signed NDAs with appropriate access controls.*

#### Step 4: Review and update the NDA template regularly.

Review the NDA template periodically to ensure that it remains up-to-date and effective. Update the template as needed to reflect changes in the organization's operations or legal requirements.

*What to look for: A current and effective NDA template.*

### Verification Steps:

- Step 1: Verify that a standard NDA template exists and has been approved by legal counsel.
- Step 2: Confirm that all employees, contractors, and other third parties who have access to sensitive information have signed the NDA.
- Step 3: Ensure that signed NDAs are stored securely with appropriate access controls.
- Step 4: Verify that the NDA template is reviewed and updated regularly.

**Azure Services Required:** Azure Active Directory, Azure DevOps (for document storage)

**Expected Outcome:** Documented confidentiality/non-disclosure agreements in place for all relevant individuals, protecting sensitive information and complying with ISO 27001:2022 requirement 6.6.

**Framework Reference:** ISO 27001:2022 Clause 6.6

**Additional Notes:** The NDA should be tailored to the specific needs of the organization and should be reviewed by legal counsel.

# Item #1: Implement Consent Management for PII Processing

Priority:

CRITICAL

Effort:

Complex

## Description:

Establish a mechanism for obtaining, recording, and revoking consent for PII processing within Azure. This ensures compliance with data privacy regulations and provides transparency to data subjects.

**Gap Addressed:** Lack of explicit details on consent management for PII processing in the cloud environment.

**Azure Portal Navigation:** Azure Portal > Azure Active Directory > App registrations > [Your App] > API permissions

## Settings to Configure:

|                 |                                                                                             |
|-----------------|---------------------------------------------------------------------------------------------|
| Setting Name:   | API permissions                                                                             |
| Current Value:  | Varies depending on existing configuration                                                  |
| Required Value: | Configure permissions to access user profile data and other PII only with explicit consent. |
| Location:       | Azure Active Directory > App registrations > [Your App] > API permissions                   |

## Step-by-Step Implementation Guide:

### Step 1: Navigate to Azure Portal > Azure Active Directory > App registrations

Click on 'Azure Active Directory' in the left navigation menu, then select 'App registrations'.  
*What to look for:* You should see a list of registered applications.

### Step 2: Select the application used for accessing PII.

Click on the application name that handles PII.  
*What to look for:* You should see the application overview page.

### Step 3: Go to API permissions

In the left menu, click 'API permissions'.  
*What to look for:* You should see a list of configured API permissions.

### Step 4: Review and adjust API permissions.

Ensure that only necessary permissions are granted. Implement a consent flow using Azure Logic Apps or similar to record user consent before accessing PII. Store consent records in Azure Storage (e.g., Azure Table Storage or Azure Cosmos DB).  
*What to look for:* Verify that permissions are minimized and a consent mechanism is in place.

### Step 5: Implement a consent revocation mechanism.

Provide a way for users to revoke consent. Update the consent record in Azure Storage when consent is revoked.  
*What to look for:* A clear process for users to revoke consent and confirmation that the revocation is recorded.

## Verification Steps:

- Step 1: Test the consent flow by attempting to access PII without consent. Verify that access is denied.
- Step 2: Grant consent and verify that access to PII is granted.
- Step 3: Revoke consent and verify that access to PII is revoked.

- Step 4: Check the consent records in Azure Storage to ensure they accurately reflect the consent status.

**Azure Services Required:** Azure Active Directory, Azure Logic Apps, Azure Storage

**Expected Outcome:** Compliance with data privacy regulations regarding consent management.

**Framework Reference:** ISO/IEC 27018:2019 9.2.1, 9.2.2

**Additional Notes:** Consider using Azure AD B2C for managing user identities and consent if applicable.

## Item #2: Implement Data Subject Rights (DSR) Request Handling

Priority:

CRITICAL

Effort:

Complex

### Description:

Establish a process for data subjects to exercise their rights (access, rectification, erasure, restriction of processing, data portability, and objection) within the Azure cloud environment.

**Gap Addressed:** Insufficient information on how data subjects can exercise their rights (access, rectification, erasure, etc.) within the Azure cloud.

**Azure Portal Navigation:** Azure Portal > Resource Groups > [Your Resource Group] > Deployments

### Settings to Configure:

|                 |                                                            |
|-----------------|------------------------------------------------------------|
| Setting Name:   | DSR Request Handling Workflow                              |
| Current Value:  | No automated workflow exists                               |
| Required Value: | Implement an automated workflow for handling DSR requests. |
| Location:       | Azure Resource Group                                       |

### Step-by-Step Implementation Guide:

#### Step 1: Create a DSR request intake form.

Use Azure Forms or a custom web application to collect DSR requests. Ensure the form captures necessary information for identifying the data subject and the specific right they wish to exercise.

*What to look for: A user-friendly form for submitting DSR requests.*

#### Step 2: Develop an Azure Logic App to process DSR requests.

Create a Logic App that triggers when a new DSR request is submitted. The Logic App should: 1) Authenticate the requestor. 2) Identify the data subject. 3) Locate the relevant PII in Azure services (e.g., Azure SQL Database, Azure Cosmos DB, Azure Storage). 4) Perform the requested action (access, rectification, erasure, etc.). 5) Document the actions taken.

*What to look for: A Logic App workflow that automates DSR request processing.*

#### Step 3: Implement Azure Functions for specific DSR actions.

Use Azure Functions to perform specific actions like data retrieval, modification, or deletion. This allows for modularity and easier maintenance.

*What to look for: Azure Functions that perform specific DSR actions.*

#### Step 4: Store DSR request logs in Azure Storage.

Maintain a detailed log of all DSR requests and the actions taken in response. Store these logs securely in Azure Storage (e.g., Azure Blob Storage or Azure Table Storage).

*What to look for: A secure and auditable log of all DSR requests.*

#### Step 5: Integrate with Azure Active Directory for user authentication.

Use Azure Active Directory to authenticate data subjects submitting DSR requests.

*What to look for: Secure authentication of data subjects.*

### Verification Steps:

- Step 1: Submit a DSR request through the intake form.
- Step 2: Verify that the Logic App triggers and processes the request.
- Step 3: Check the Azure Function logs to ensure the requested action was performed correctly.

- Step 4: Verify that the DSR request log in Azure Storage is updated with the details of the request and the actions taken.
- Step 5: Confirm that the data subject receives a confirmation of the completed request.

**Azure Services Required:** Azure Logic Apps, Azure Functions, Azure Storage, Azure Active Directory

**Expected Outcome:** Compliance with data privacy regulations regarding data subject rights.

**Framework Reference:** ISO/IEC 27018:2019 9.3.1, 9.3.2, 9.3.3, 9.3.4, 9.3.5, 9.3.6

**Additional Notes:** Ensure that the DSR request handling process complies with all applicable data privacy regulations (e.g., GDPR, CCPA).

## Item #4: Define PII Protection Responsibilities in Contractual Agreements

Priority:

CRITICAL

Effort:

Complex

### Description:

Clearly specify the PII protection responsibilities of all organizations involved in providing or using the cloud services, including the public cloud PII processor, its sub-contractors, and the cloud service customer.

**Gap Addressed:** The document does not explicitly address the contractual agreements needed to specify PII protection responsibilities between the cloud service provider, its subcontractors, and the cloud service customer, as highlighted in ISO/IEC 27018:2019.

**Azure Portal Navigation:** N/A - Requires legal review and updates to contractual agreements.

### Settings to Configure:

|                 |                                                                                  |
|-----------------|----------------------------------------------------------------------------------|
| Setting Name:   | Contractual Agreements                                                           |
| Current Value:  | Varies depending on existing agreements                                          |
| Required Value: | Update contractual agreements to clearly define PII protection responsibilities. |
| Location:       | Legal Department                                                                 |

### Step-by-Step Implementation Guide:

#### Step 1: Review existing contractual agreements.

Review all existing contractual agreements with customers and sub-contractors to identify any gaps in PII protection responsibilities.

*What to look for: Gaps in PII protection responsibilities.*

#### Step 2: Update contractual agreements to clearly define PII protection responsibilities.

Update the contractual agreements to clearly define the PII protection responsibilities of: 1) The cloud service provider (Microsoft Azure). 2) Sub-contractors. 3) The cloud service customer. Include specific clauses addressing: a) Data security measures. b) Data breach notification procedures. c) Data subject rights. d) Data retention policies. e) Compliance with applicable data privacy regulations.

*What to look for: Clear and comprehensive PII protection clauses in contractual agreements.*

#### Step 3: Ensure that all parties understand their PII protection responsibilities.

Communicate the updated contractual agreements to all relevant parties and ensure that they understand their PII protection responsibilities.

*What to look for: Confirmation that all parties understand their PII protection responsibilities.*

### Verification Steps:

- Step 1: Review the updated contractual agreements with legal counsel.
- Step 2: Obtain sign-off from all relevant parties.
- Step 3: Conduct periodic reviews of the contractual agreements to ensure they remain up-to-date.

**Azure Services Required:** Legal Agreements, Data Processing Agreements

**Expected Outcome:** Clear allocation of PII protection responsibilities among all parties.

**Framework Reference:** ISO/IEC 27018:2019 5.1.1, 5.1.2, 5.1.3

**Additional Notes:** Consult with legal counsel to ensure that the contractual agreements comply with all applicable data privacy regulations.

## Item #2: Implement X.509 Management Certificates for Infrastructure and Platform Services Management

Priority:

HIGH

Effort:

Moderate

### Description:

Use X.509 management certificates for secure authentication and authorization of infrastructure and platform services management tasks. This provides a more secure alternative to username/password authentication.

**Gap Addressed:** No explicit mention of using X.509 management certificates for infrastructure and platform services management in Azure.

**Azure Portal Navigation:** Azure Portal > Azure Active Directory > App registrations

### Settings to Configure:

|                 |                                                                                               |
|-----------------|-----------------------------------------------------------------------------------------------|
| Setting Name:   | Authentication method for service principals                                                  |
| Current Value:  | Client secrets                                                                                |
| Required Value: | Certificates                                                                                  |
| Location:       | Azure Active Directory > App registrations > [Your App Registration] > Certificates & secrets |

### Step-by-Step Implementation Guide:

#### Step 1: Navigate to Azure Portal > Azure Active Directory > App registrations

Click on 'Azure Active Directory' in the left navigation menu, then click 'App registrations'.

*What to look for:* You should see the list of app registrations.

#### Step 2: Select the App Registration used for infrastructure management

Choose the app registration that your infrastructure management tools (e.g., Terraform, Ansible) use to authenticate to Azure.

*What to look for:* You should see the overview page for the selected app registration.

#### Step 3: Go to Certificates & secrets

In the left menu, click 'Certificates & secrets'.

*What to look for:* You should see the 'Certificates' and 'Client secrets' tabs.

#### Step 4: Upload an X.509 certificate

Click 'Upload certificate'. Select the X.509 certificate file (.cer) and click 'Add'.

*What to look for:* The uploaded certificate should appear in the 'Certificates' list.

#### Step 5: Update your infrastructure management tools to use the certificate for authentication

Configure your tools (e.g., Terraform, Ansible) to use the certificate for authentication instead of client secrets. This typically involves providing the certificate file and the certificate's thumbprint.

*What to look for:* Your infrastructure management tools should be able to authenticate to Azure using the certificate.

### Verification Steps:

- Step 1: Verify that your infrastructure management tools can successfully authenticate to Azure using the certificate.
- Step 2: Remove any client secrets associated with the app registration to ensure that only certificate-based authentication is allowed.

**Azure Services Required:** Azure Active Directory, Azure Resource Manager

**Expected Outcome:** Infrastructure and platform services management tasks are authenticated using X.509 certificates, improving security and reducing reliance on secrets.

**Framework Reference:** Azure Security Benchmark v3 - IM-4: Use managed identities to access Azure resources

**Additional Notes:** Ensure that the X.509 certificate is stored securely and rotated regularly.

### Item #3: Detail the Process for Secure Connectivity to Databases Using Secure Connection Strings

Priority: HIGH

Effort: Moderate

**Description:**

Provide a detailed process for securely connecting to databases using secure connection strings, including best practices for storing and managing connection strings.

**Gap Addressed:** The document does not explicitly detail the process for secure connectivity to databases using secure connection strings, only mentions its use.

**Azure Portal Navigation:** Azure Portal > Key Vault > [Your Key Vault] > Secrets

**Settings to Configure:**

|                 |                                                                      |
|-----------------|----------------------------------------------------------------------|
| Setting Name:   | Database connection string                                           |
| Current Value:  | Hardcoded in application configuration                               |
| Required Value: | Stored securely in Azure Key Vault and accessed via Managed Identity |
| Location:       | Azure Key Vault > Secrets                                            |

**Step-by-Step Implementation Guide:**

**Step 1: Navigate to Azure Portal > Key Vault > [Your Key Vault] > Secrets**

Click on 'Key Vault' in the left navigation menu, select your Key Vault, and then click 'Secrets'.  
*What to look for: You should see the list of secrets in your Key Vault.*

**Step 2: Create a new secret to store the database connection string**

Click '+ Generate/Import'. Enter a name for the secret (e.g., 'DatabaseConnectionString'). Paste the database connection string into the 'Value' field. Ensure the connection string includes 'Encrypt=True;TrustServerCertificate=False;Connection Timeout=30;' for secure communication. Set 'Activation date' and 'Expiration date' as needed. Click 'Create'.  
*What to look for: The new secret should appear in the list of secrets.*

**Step 3: Enable Managed Identity for your application (e.g., App Service, Function App)**

Navigate to your application in the Azure Portal. Go to 'Settings' > 'Identity'. Set 'System assigned managed identity' to 'On'.  
*What to look for: A system-assigned managed identity should be enabled for your application.*

**Step 4: Grant your application's Managed Identity access to the Key Vault**

Navigate to your Key Vault in the Azure Portal. Go to 'Access policies'. Click '+ Add Access Policy'. Select 'Get' permission under 'Secret permissions'. Select your application's Managed Identity as the 'Principal'. Click 'Add'.  
*What to look for: Your application's Managed Identity should have 'Get' permission for secrets in the Key Vault.*

**Step 5: Update your application code to retrieve the connection string from Key Vault using Managed Identity**

Modify your application code to use the Azure.Identity and Azure.Security.KeyVault.Secrets NuGet packages (or equivalent for your language). Use the DefaultAzureCredential to authenticate to Key Vault and retrieve the secret value (connection string).  
*What to look for: Your application should be able to retrieve the connection string from Key Vault without using hardcoded credentials.*

### ***Verification Steps:***

- Step 1: Verify that your application can successfully connect to the database using the connection string retrieved from Key Vault.
- Step 2: Ensure that the connection string is not stored in any configuration files or environment variables.
- Step 3: Rotate the database connection string regularly and update the secret in Key Vault.

**Azure Services Required:** Azure SQL Database, Azure Key Vault, App Service

**Expected Outcome:** Database connection strings are stored securely in Azure Key Vault and accessed via Managed Identity, reducing the risk of credential exposure.

**Framework Reference:** Azure Security Benchmark v3 - DP-3: Store credentials in secure storage

**Additional Notes:** Consider using Azure SQL Database's built-in features for managing connections, such as connection pooling and retry logic.

## Item #4: Implement Mechanisms for Data Subject Rights

Priority:

HIGH

Effort:

Complex

### Description:

Establish clear processes for facilitating and managing data subject rights (access, rectification, erasure, restriction, portability, objection) as required by GDPR Articles 15-22. Provide specific instructions and forms for data subjects to exercise their rights.

**Gap Addressed:** Limited information on how data subject rights (access, rectification, erasure, restriction, portability, objection) are facilitated and managed in practice, beyond stating that procedures are documented per GDPR Articles 15-22. Specific processes for handling requests are not detailed.

**Azure Portal Navigation:** N/A - Documentation and workflow implementation

### Settings to Configure:

|                 |                                                            |
|-----------------|------------------------------------------------------------|
| Setting Name:   | Data Subject Rights Procedures                             |
| Current Value:  | General documentation only                                 |
| Required Value: | Detailed procedures and forms for each data subject right. |
| Location:       | Documentation repository and data subject rights portal    |

### Step-by-Step Implementation Guide:

#### Step 1: Create a Data Subject Rights Portal

Develop a portal or webpage where data subjects can submit requests to exercise their rights. This portal should provide clear instructions and forms for each type of request.

*What to look for: A user-friendly portal with clear instructions and forms for data subject rights requests.*

#### Step 2: Develop Procedures for Each Right

Create detailed procedures for handling each type of data subject rights request, including access, rectification, erasure, restriction, portability, and objection. These procedures should specify the steps involved, the roles and responsibilities of personnel, and the timelines for responding to requests.

*What to look for: Documented procedures for each data subject right, including timelines and responsibilities.*

#### Step 3: Implement Automated Workflows (Optional)

Consider implementing automated workflows using Azure Logic Apps or Azure Functions to streamline the processing of data subject rights requests. This can help to improve efficiency and reduce the risk of errors.

*What to look for: Automated workflows for processing data subject rights requests.*

#### Step 4: Train Personnel

Train personnel on the procedures for handling data subject rights requests. Ensure that they understand their responsibilities and are able to respond to requests in a timely and accurate manner.

*What to look for: Training records for personnel involved in handling data subject rights requests.*

### Verification Steps:

- Step 1: Test the data subject rights portal to ensure it is functioning correctly.
- Step 2: Review the procedures for handling data subject rights requests to ensure they are complete and accurate.

- Step 3: Verify that personnel are trained on the procedures for handling data subject rights requests.

**Azure Services Required:** Azure Active Directory, Azure Logic Apps, Azure Functions

**Expected Outcome:** Compliance with GDPR Articles 15-22, demonstrating a commitment to data subject rights.

**Framework Reference:** GDPR Articles 15-22

**Additional Notes:** Ensure that data subjects are informed of their rights and how to exercise them. Provide clear and concise information in a language they understand.

## Item #5: Implement Mechanisms for International Data Transfers

Priority:

HIGH

Effort:

Complex

### Description:

Establish mechanisms for international data transfers and ensure adequate protection when transferring data outside the EU, as required by GDPR Chapter V. This may involve using Standard Contractual Clauses (SCCs), Binding Corporate Rules (BCRs), or other approved transfer mechanisms.

**Gap Addressed:** No explicit mention of mechanisms for international data transfers and ensuring adequate protection when transferring data outside the EU, as required by GDPR Chapter V.

**Azure Portal Navigation:** N/A - Documentation and contractual agreements

### Settings to Configure:

|                 |                                                                            |
|-----------------|----------------------------------------------------------------------------|
| Setting Name:   | International Data Transfer Mechanisms                                     |
| Current Value:  | None specified                                                             |
| Required Value: | Documented mechanisms for international data transfers (e.g., SCCs, BCRs). |
| Location:       | Legal agreements and data transfer documentation                           |

### Step-by-Step Implementation Guide:

#### Step 1: Identify International Data Transfers

Identify all data transfers that involve transferring personal data outside the European Economic Area (EEA).

*What to look for: A list of all international data transfers.*

#### Step 2: Implement Appropriate Transfer Mechanisms

For each international data transfer, implement an appropriate transfer mechanism, such as Standard Contractual Clauses (SCCs), Binding Corporate Rules (BCRs), or other approved mechanisms. Ensure that the transfer mechanism provides adequate protection for the personal data being transferred.

*What to look for: Signed SCCs, approved BCRs, or other documentation demonstrating compliance with GDPR Chapter V.*

#### Step 3: Conduct Transfer Impact Assessments (TIAs)

Conduct Transfer Impact Assessments (TIAs) to assess the level of protection afforded to personal data in the recipient country and to identify any supplementary measures that may be necessary to ensure adequate protection.

*What to look for: Completed TIAs for each international data transfer.*

#### Step 4: Implement Supplementary Measures (If Necessary)

If the TIA identifies any risks to the protection of personal data, implement supplementary measures to mitigate those risks. This may include encryption, pseudonymization, or other technical and organizational measures.

*What to look for: Documentation of supplementary measures implemented to protect personal data during international transfers.*

### Verification Steps:

- Step 1: Review the list of international data transfers to ensure it is complete and accurate.
- Step 2: Verify that appropriate transfer mechanisms are in place for each international data transfer.

- Step 3: Confirm that TIAs have been conducted and that supplementary measures have been implemented (if necessary).

**Azure Services Required:** Azure Policy, Azure Key Vault

**Expected Outcome:** Compliance with GDPR Chapter V, ensuring adequate protection for personal data transferred outside the EU.

**Framework Reference:** GDPR Chapter V

**Additional Notes:** Stay up-to-date on the latest guidance from the European Data Protection Board (EDPB) on international data transfers.

### Item #3: Document Remote Working Security Measures

Priority:

HIGH

Effort:

Moderate

#### Description:

Develop and document specific security measures for remote working, addressing risks associated with accessing company resources from remote locations. This includes policies on device security, network security, and data protection.

**Gap Addressed:** Missing details on remote working security measures (6.7)

**Azure Portal Navigation:** N/A - Policy and Configuration

#### Settings to Configure:

|                 |                                                                                                        |
|-----------------|--------------------------------------------------------------------------------------------------------|
| Setting Name:   | N/A                                                                                                    |
| Current Value:  | No documented policy                                                                                   |
| Required Value: | A documented policy covering device security, network security, and data protection for remote workers |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint)                                              |

#### Step-by-Step Implementation Guide:

##### Step 1: Develop a comprehensive remote working security policy.

The policy should address topics such as acceptable use of company devices, secure network access (VPN requirements), data protection measures (encryption, data loss prevention), and incident reporting procedures.

*What to look for: A well-defined policy covering all aspects of remote working security.*

##### Step 2: Enforce device security measures using Microsoft Intune.

Azure Portal > Microsoft Intune > Devices > Configuration profiles. Create configuration profiles to enforce password policies, encryption, and software updates on company-owned devices. Consider requiring device enrollment for access to company resources.

*What to look for: Configuration profiles deployed to remote worker devices.*

##### Step 3: Implement secure network access using Azure VPN Gateway.

Azure Portal > Virtual networks > Gateways > Virtual network gateways. Configure Azure VPN Gateway to provide secure remote access to the corporate network. Require multi-factor authentication (MFA) for VPN connections.

*What to look for: A properly configured Azure VPN Gateway with MFA enabled.*

##### Step 4: Implement data loss prevention (DLP) measures.

Azure Portal > Microsoft Purview > Data loss prevention. Configure DLP policies to prevent sensitive data from being leaked outside the organization. Monitor and audit data access and transfer activities.

*What to look for: DLP policies configured to protect sensitive data.*

##### Step 5: Provide security awareness training to remote workers.

Educate remote workers on the risks associated with remote working and the security measures they need to follow. Conduct regular security awareness training sessions.

*What to look for: Evidence of security awareness training for remote workers.*

#### Verification Steps:

- Step 1: Verify that a comprehensive remote working security policy exists and has been communicated to all remote workers.

- Step 2: Confirm that device security measures are enforced using Microsoft Intune.
- Step 3: Ensure that secure network access is provided through Azure VPN Gateway with MFA enabled.
- Step 4: Verify that DLP policies are in place to protect sensitive data.
- Step 5: Confirm that remote workers have received security awareness training.

**Azure Services Required:** Azure Active Directory, Microsoft Intune, Azure VPN Gateway

**Expected Outcome:** A documented and implemented remote working security policy that protects company resources and data from unauthorized access and loss.

**Framework Reference:** ISO 27001:2022 Clause 6.7

**Additional Notes:** The remote working security policy should be reviewed and updated regularly to reflect changes in the organization's operations and threat landscape.

## Item #4: Establish a Mechanism for Reporting Security Events

Priority:

HIGH

Effort:

Quick

### Description:

Create a clear and documented mechanism for personnel to report observed or suspected information security events. This includes defining reporting channels, escalation procedures, and responsibilities.

**Gap Addressed:** No explicit mechanism described for personnel to report observed or suspected information security events (6.8)

**Azure Portal Navigation:** N/A - Policy and Communication

### Settings to Configure:

|                 |                                                                             |
|-----------------|-----------------------------------------------------------------------------|
| Setting Name:   | N/A                                                                         |
| Current Value:  | No documented policy                                                        |
| Required Value: | A documented policy outlining the process for reporting security incidents. |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint)                   |

### Step-by-Step Implementation Guide:

#### Step 1: Develop and document an incident reporting policy.

The policy should clearly define what constitutes a security incident, how to report it, and who to report it to. Include multiple reporting channels (e.g., email, phone, online form).

*What to look for: A well-defined incident reporting policy.*

#### Step 2: Communicate the incident reporting policy to all personnel.

Ensure that all employees, contractors, and other relevant parties are aware of the incident reporting policy and how to use it. Provide training on how to identify and report security incidents.

*What to look for: Evidence that the policy has been communicated and training has been provided.*

#### Step 3: Establish an incident response team.

Form a dedicated incident response team with clearly defined roles and responsibilities. The team should be responsible for investigating and resolving security incidents.

*What to look for: A designated incident response team with defined roles and responsibilities.*

#### Step 4: Test the incident reporting process regularly.

Conduct regular simulations to test the effectiveness of the incident reporting process. Identify and address any weaknesses in the process.

*What to look for: Evidence of regular testing and improvement of the incident reporting process.*

### Verification Steps:

- Step 1: Verify that an incident reporting policy exists and has been communicated to all personnel.
- Step 2: Confirm that multiple reporting channels are available.
- Step 3: Ensure that an incident response team is in place with defined roles and responsibilities.
- Step 4: Verify that the incident reporting process is tested regularly.

**Azure Services Required:** Azure Sentinel, Microsoft Teams (for communication)

**Expected Outcome:** A clear and effective mechanism for reporting security incidents, enabling timely detection and response to security threats.

**Framework Reference:** ISO 27001:2022 Clause 6.8

**Additional Notes:** The incident reporting policy should be reviewed and updated regularly to reflect changes in the organization's operations and threat landscape.

## Item #6: Implement Network Segregation

Priority:

HIGH

Effort:

Complex

### Description:

Implement network segregation to isolate sensitive systems and data from less secure networks. This reduces the impact of potential security breaches and limits the spread of malware.

**Gap Addressed:** Lack of detail on segregation of networks (8.22)

**Azure Portal Navigation:** Azure Portal > Virtual networks

### Settings to Configure:

|                 |                                                              |
|-----------------|--------------------------------------------------------------|
| Setting Name:   | N/A                                                          |
| Current Value:  | Limited segmentation                                         |
| Required Value: | A documented policy outlining network segmentation strategy. |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint)    |

### Step-by-Step Implementation Guide:

#### Step 1: Develop a network segmentation policy.

The policy should define the different network segments, the security requirements for each segment, and the rules for traffic flow between segments.

*What to look for: A well-defined network segmentation policy.*

#### Step 2: Create separate Azure Virtual Networks (VNets) for different environments (e.g., production, development, test).

Azure Portal > Virtual networks > + Create. Create separate VNets to isolate different environments. Use different address spaces for each VNet to avoid IP address conflicts.

*What to look for: Separate VNets for different environments.*

#### Step 3: Implement Network Security Groups (NSGs) to control traffic flow between VNets and subnets.

Azure Portal > Network security groups > + Create. Create NSGs to restrict traffic based on source and destination IP addresses, ports, and protocols. Apply NSGs to VNets and subnets to enforce network segmentation.

*What to look for: NSGs configured to restrict traffic between VNets and subnets.*

#### Step 4: Implement Azure Firewall to inspect and filter traffic between VNets and the internet.

Azure Portal > Firewalls > + Create. Deploy Azure Firewall to inspect and filter traffic based on application-level rules. Use Azure Firewall to prevent unauthorized access to sensitive resources.

*What to look for: Azure Firewall deployed to inspect and filter traffic.*

#### Step 5: Use User-Defined Routes (UDRs) to control traffic flow between VNets.

Azure Portal > Route tables > + Create. Create UDRs to route traffic between VNets through Azure Firewall or other security appliances. Use UDRs to enforce network segmentation and prevent unauthorized access.

*What to look for: UDRs configured to control traffic flow between VNets.*

### Verification Steps:

- Step 1: Verify that a network segmentation policy exists and has been communicated to all relevant personnel.

- Step 2: Confirm that separate VNets have been created for different environments.
- Step 3: Ensure that NSGs are in place to control traffic flow between VNets and subnets.
- Step 4: Verify that Azure Firewall is deployed to inspect and filter traffic between VNets and the internet.
- Step 5: Confirm that UDRs are configured to control traffic flow between VNets.

**Azure Services Required:** Azure Virtual Network, Azure Network Security Groups, Azure Firewall

**Expected Outcome:** Effective network segregation, reducing the impact of potential security breaches and limiting the spread of malware.

**Framework Reference:** ISO 27001:2022 Clause 8.22

**Additional Notes:** The network segmentation policy should be reviewed and updated regularly to reflect changes in the organization's operations and threat landscape.

## Item #7: Implement a Secure Development Lifecycle (SDLC)

Priority:

HIGH

Effort:

Complex

### Description:

Establish and implement a Secure Development Lifecycle (SDLC) to ensure that security is integrated into all stages of software development. This includes security requirements gathering, secure coding practices, security testing, and vulnerability management.

**Gap Addressed:** No mention of secure development lifecycle (8.25) or application security requirements (8.26) beyond vulnerability scanning

**Azure Portal Navigation:** N/A - Policy and Process Implementation

### Settings to Configure:

|                 |                                                                       |
|-----------------|-----------------------------------------------------------------------|
| Setting Name:   | N/A                                                                   |
| Current Value:  | No documented SDLC                                                    |
| Required Value: | A documented SDLC policy covering all stages of software development. |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint)             |

### Step-by-Step Implementation Guide:

#### Step 1: Develop a comprehensive Secure Development Lifecycle (SDLC) policy.

The policy should define the security requirements for each stage of the software development process, including requirements gathering, design, coding, testing, and deployment.

*What to look for: A well-defined SDLC policy.*

#### Step 2: Integrate security requirements into the requirements gathering process.

Ensure that security requirements are identified and documented during the requirements gathering phase. Use threat modeling techniques to identify potential security risks.

*What to look for: Documented security requirements for each software project.*

#### Step 3: Implement secure coding practices.

Train developers on secure coding practices and provide them with tools to help them write secure code. Use static code analysis tools to identify potential vulnerabilities in the code.

*What to look for: Developers trained on secure coding practices and using secure coding tools.*

#### Step 4: Implement security testing throughout the SDLC.

Conduct regular security testing, including static code analysis, dynamic application security testing (DAST), and penetration testing. Use Azure Security Center to identify and remediate vulnerabilities.

*What to look for: Regular security testing conducted throughout the SDLC.*

#### Step 5: Implement vulnerability management procedures.

Establish procedures for identifying, tracking, and remediating vulnerabilities. Use a vulnerability management system to track the status of vulnerabilities and ensure that they are addressed in a timely manner.

*What to look for: A vulnerability management system in place to track and remediate vulnerabilities.*

#### Step 6: Use Azure Container Registry to store and manage container images securely.

Azure Portal > Container registries > + Create. Use Azure Container Registry to store and manage container images securely. Scan container images for vulnerabilities before deploying them to production.

*What to look for: Secure storage and management of container images in Azure Container Registry.*

### ***Verification Steps:***

- Step 1: Verify that a comprehensive SDLC policy exists and has been communicated to all relevant personnel.
- Step 2: Confirm that security requirements are integrated into the requirements gathering process.
- Step 3: Ensure that developers are trained on secure coding practices and using secure coding tools.
- Step 4: Verify that security testing is conducted throughout the SDLC.
- Step 5: Confirm that a vulnerability management system is in place to track and remediate vulnerabilities.
- Step 6: Ensure that Azure Container Registry is used to store and manage container images securely.

**Azure Services Required:** Azure DevOps, Azure Security Center, Azure Container Registry

**Expected Outcome:** A secure development lifecycle that integrates security into all stages of software development, reducing the risk of vulnerabilities and security breaches.

**Framework Reference:** ISO 27001:2022 Clauses 8.25 and 8.26

**Additional Notes:** The SDLC policy should be reviewed and updated regularly to reflect changes in the organization's operations and threat landscape.

## Item #3: Document Cryptography Usage and Customer Capabilities

Priority:

HIGH

Effort:

Moderate

### Description:

Provide detailed documentation regarding the specific circumstances under which cryptography is used to protect PII in Azure and the capabilities offered to customers for applying their own cryptographic protection.

**Gap Addressed:** Limited transparency regarding the specific circumstances in which cryptography is used to protect PII and the capabilities offered to customers for applying their own cryptographic protection.

**Azure Portal Navigation:** Azure Portal > Documentation > Azure Services

### Settings to Configure:

|                 |                                                                                     |
|-----------------|-------------------------------------------------------------------------------------|
| Setting Name:   | Cryptography Documentation                                                          |
| Current Value:  | Limited or no documentation available                                               |
| Required Value: | Create comprehensive documentation on cryptography usage and customer capabilities. |
| Location:       | Internal Documentation Repository                                                   |

### Step-by-Step Implementation Guide:

#### Step 1: Document Azure's use of cryptography for PII protection.

Create a document that details how Azure uses cryptography to protect PII at rest and in transit. Include information on: 1) Encryption algorithms used. 2) Key management practices. 3) Compliance certifications. 4) Specific Azure services that utilize encryption (e.g., Azure Storage Service Encryption, Transparent Data Encryption for SQL Database, Azure Disk Encryption).

*What to look for: A comprehensive document detailing Azure's cryptography practices.*

#### Step 2: Document customer capabilities for applying their own cryptographic protection.

Create a document that outlines the capabilities available to customers for applying their own cryptographic protection. Include information on: 1) Azure Key Vault for managing keys and secrets. 2) Bring Your Own Key (BYOK) options for various Azure services. 3) Client-side encryption options. 4) Guidance on selecting appropriate cryptographic solutions.

*What to look for: A comprehensive document detailing customer cryptography capabilities.*

#### Step 3: Make the documentation readily available to customers.

Publish the documentation in a location that is easily accessible to customers (e.g., a customer portal, a knowledge base).

*What to look for: Easy access to cryptography documentation for customers.*

### Verification Steps:

- Step 1: Review the documentation to ensure it is accurate and comprehensive.
- Step 2: Verify that the documentation is easily accessible to customers.
- Step 3: Conduct a periodic review of the documentation to ensure it remains up-to-date.

**Azure Services Required:** Azure Key Vault, Azure Storage, Azure SQL Database, Azure Disk Encryption

**Expected Outcome:** Increased transparency regarding cryptography usage and customer capabilities.

**Framework Reference:** ISO/IEC 27018:2019 8.1.1, 8.1.2

**Additional Notes:** Regularly update the documentation to reflect changes in Azure's cryptography practices and customer capabilities.

## Item #5: Enhance Physical Security Perimeters and Entry Controls

Priority:

MEDIUM

Effort:

Complex

### Description:

Implement and document physical security measures to protect physical perimeters and control entry to sensitive areas. This includes access control systems, surveillance, and environmental controls.

**Gap Addressed:** Limited information on physical security perimeters and entry controls (7.1 and 7.2)

**Azure Portal Navigation:** N/A - Physical Security Implementation

### Settings to Configure:

|                 |                                                                               |
|-----------------|-------------------------------------------------------------------------------|
| Setting Name:   | N/A                                                                           |
| Current Value:  | Limited documentation                                                         |
| Required Value: | A documented policy covering physical security perimeters and entry controls. |
| Location:       | Document Repository (e.g., Azure DevOps Wiki, SharePoint)                     |

### Step-by-Step Implementation Guide:

#### Step 1: Develop a comprehensive physical security policy.

The policy should address topics such as perimeter security, access control, surveillance, environmental controls, and visitor management.

*What to look for: A well-defined physical security policy.*

#### Step 2: Implement access control systems.

Install access control systems (e.g., key card readers, biometric scanners) to restrict access to sensitive areas. Configure access control lists to grant access only to authorized personnel.

*What to look for: Functional access control systems with appropriate access control lists.*

#### Step 3: Implement surveillance systems.

Install surveillance cameras to monitor physical perimeters and sensitive areas. Configure the cameras to record footage and store it securely. Consider using Azure Video Analyzer for intelligent video analytics.

*What to look for: Functional surveillance systems with secure storage of footage.*

#### Step 4: Implement environmental controls.

Implement environmental controls (e.g., temperature and humidity monitoring, fire suppression systems) to protect sensitive equipment and data. Consider using Azure IoT Hub to collect and analyze sensor data.

*What to look for: Functional environmental controls with monitoring and alerting capabilities.*

#### Step 5: Implement visitor management procedures.

Establish procedures for managing visitors to sensitive areas. Require visitors to sign in and out, and provide them with appropriate identification badges.

*What to look for: Documented visitor management procedures.*

### Verification Steps:

- Step 1: Verify that a comprehensive physical security policy exists and has been communicated to all personnel.
- Step 2: Confirm that access control systems are in place and functioning correctly.
- Step 3: Ensure that surveillance systems are in place and recording footage securely.

- Step 4: Verify that environmental controls are in place and functioning correctly.
- Step 5: Confirm that visitor management procedures are in place and being followed.

**Azure Services Required:** Azure IoT Hub (for sensor data), Azure Video Analyzer (for surveillance)

**Expected Outcome:** Enhanced physical security perimeters and entry controls, protecting sensitive areas and data from unauthorized access and damage.

**Framework Reference:** ISO 27001:2022 Clauses 7.1 and 7.2

**Additional Notes:** The physical security policy should be reviewed and updated regularly to reflect changes in the organization's operations and threat landscape.